

1. INTRODUCCION

Este informe detalla las medidas de seguridad aplicadas a la plantilla del servidor SUSE Linux Enterprise Server 15 SP6 para cumplir con el nivel Esquema Nacional de Seguridad (ENS adelante en este informe) MEDIO con refuerzos (requeridos por el cliente), para garantizar la protección de los datos críticos y la continuidad de los servicios. En los siguientes apartados se detallará la información específica sobre las configuraciones realizadas para proteger sus datos y garantizar la estabilidad del sistema.

1.1. OBJETO

El presente informe tiene como objeto principal ofrecer una descripción exhaustiva de las medidas de seguridad implementadas en el servidor SUSE Linux Enterprise Server 15 SP6. Se detallarán las políticas y configuraciones aplicadas con el fin de resguardar la integridad, confidencialidad y disponibilidad de los datos críticos y asegurar la continuidad de los servicios que se encuentran por encima.

1.2. ALCANCE

Este informe tiene como objetivo presentar una visión general de las medidas de seguridad aplicadas en el servidor SUSE Linux Enterprise Server 15 SP6 con interfaz gráfica. El producto en cuestión debe estar registrado en el *Centro de Clientes* del propio fabricante bajo una licencia de uso. Ofrecerá una descripción general de las configuraciones y prácticas implementadas para proteger los datos críticos y garantizar la estabilidad del sistema. A través de este informe, los clientes obtendrán una comprensión general de cómo se abordan los aspectos de seguridad en dicho servidor.

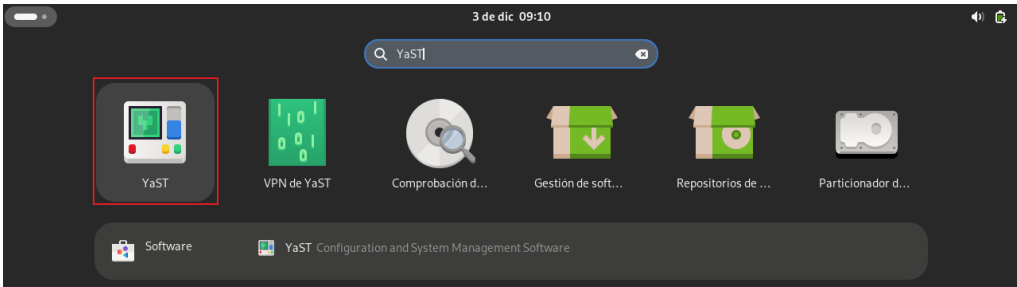
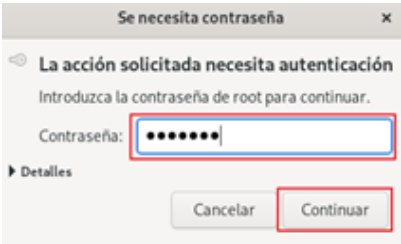
2. MEDIDAS DE SEGURIDAD APLICADAS

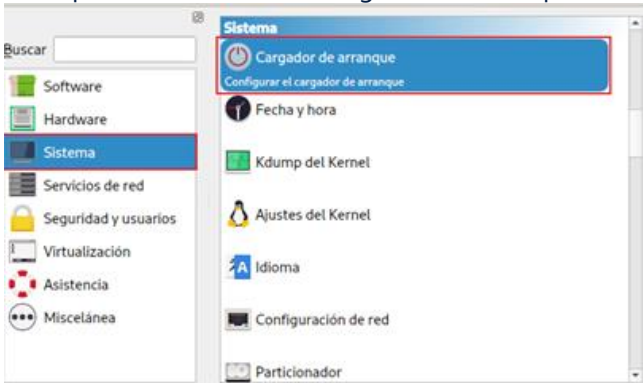
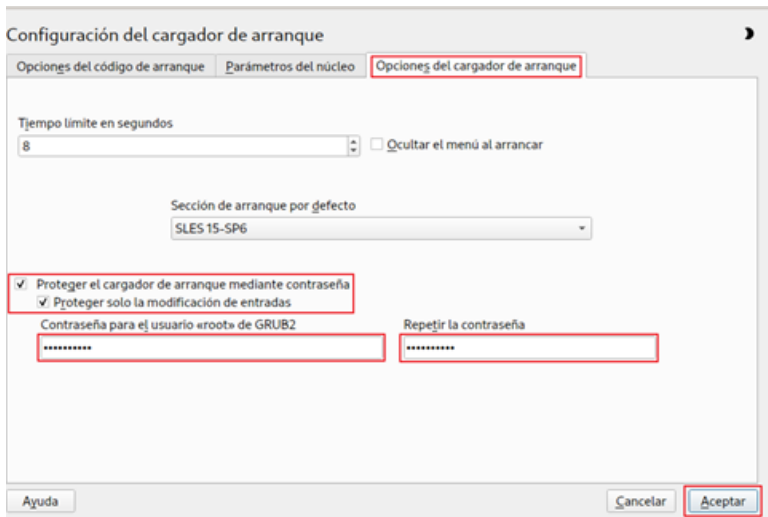
Estas medidas están diseñadas para proteger la integridad de los datos y garantizar la continuidad de nuestros servicios. A lo largo de este informe, se detallan estrategias y configuraciones clave para mejorar la seguridad en el entorno del servidor.

2.1. CONFIGURACIÓN SEGURA DEL ARRANQUE DEL SISTEMA

La seguridad de **contraseña de GRUB** en sistemas Linux es crucial. Este informe destaca las medidas esenciales para proteger eficazmente este componente crítico del proceso de inicio. Mantener GRUB seguro es fundamental para garantizar la integridad del sistema y los datos.

Para este proceso de protección del gestor de arranque, se debe utilizar la herramienta YaST que viene preinstalada en el sistema. Se establece como usuario "root" y una contraseña compleja. Como medida adicional, se restringe la edición de GRUB del sistema solo para usuarios con privilegios de administrador. A continuación, se detallan los pasos para realizar dicha medida de seguridad.

PASO	CONFIGURACIÓN
1.	Desde la interfaz gráfica "GNOME" se debe buscar la herramienta "YaST" 
2.	Introduzca la contraseña del usuario administrador o del usuario con permisos de "root" 

PASO	CONFIGURACIÓN
3.	Dentro del centro de control YaST, se debe dirigir hacia el apartado “Sistema” y dentro del apartado seleccionar “Cargador de arranque” 
4.	Una vez se encuentre en la ventana “YaST2 – Cargador de arranque”, despliegue la pestaña Opciones del cargador de arranque y habilite “Proteger el cargador de arranque mediante contraseña” y “Proteger solo modificación de entradas”. Posteriormente pulse “Aceptar”. 

2.2. CONTRASEÑA SEGURA DE ROOT

Se establece una **contraseña segura de root** al inicio para evitar que un atacante pueda editarlo. Además, los siguientes pasos de aplicación son **búsqueda de cuentas sin contraseña** y **usuarios con UID 0 que no sean root**.

PASO	CONFIGURACIÓN
1.	Desde la “Terminal”, se procederá a cambiar la contraseña de “root” con el siguiente comando

PASO	CONFIGURACIÓN
	<pre>admin@localhost:~> sudo passwd root</pre> <pre>[sudo] contraseña para root:</pre> <pre>Nueva contraseña:</pre> <pre>Vuelva a escribir la nueva contraseña:</pre> <pre>passwd: contraseña <u>actualizada</u> correctamente</pre> Debe asegurarse de que la contraseña cumple con el mínimo de complejidad, aunque más adelante se podrá modificar dichos valores.
2.	Asegúrese de que puede entrar con el usuario "root" para evitar posibles errores de acceso a la cuenta de administrador. <pre>admin@localhost:~> su -</pre> <pre>Contraseña:</pre> <pre>localhost:~ # whoami</pre> <pre>root</pre>

2.3. VERIFICACIÓN DE CUENTAS SIN CONTRASEÑA

Aunque el sistema esté recién instalado, se explica el proceso manual para encontrar aquellos usuarios que no tengan una contraseña configurada a su cuenta.

PASO	CONFIGURACIÓN
1.	Abra la terminal para ejecutar el siguiente comando
2.	<pre>admin@localhost:~> sudo cat /etc/shadow cut -d":" -f2 grep ":\$" cut -d":" -f1</pre> <pre>admin@localhost:~> █</pre>
3.	El comando no debería devolver ningún resultado por pantalla, si por el contrario, sale algún resultado, significaría que esos usuarios no tienen contraseña configurada y deben ser eliminados.

2.4. FORTIFICACIÓN DEL KERNEL

La configuración adecuada de los parámetros del kernel en sistemas Linux es esencial para optimizar el rendimiento y la estabilidad del sistema. Este apartado se adentra en la importancia de ajustar los parámetros del kernel según las necesidades específicas del entorno y que cumpla un mínimo de seguridad. A continuación, se detallan todos los parámetros configurados.

La configuración de este paso está dentro del fichero /etc/sysctl.conf.

PARÁMETROS
<pre>#</pre> <pre># Deshabilitar ping</pre> <pre>#</pre> <pre>#net.ipv4.icmp_echo_ignore_all = 1</pre> <pre>#</pre> <pre># Paquetes entre interfaces (desactivar si el equipo no actua de router)</pre>

PARÁMETROS

```
#
#net.ipv4.ip_forward = 0
#
# Evitar la modificacion de tablas de encaminamiento
#
net.ipv4.conf.all.send_redirects = 0
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.default.accept_redirects = 0
net.ipv4.conf.default.send_redirects = 0
net.ipv4.conf.default.secure_redirects = 0
net.ipv4.conf.all.secure_redirects = 0
#
# Deshabilitar el source routing
#
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.conf.default.accept_source_route = 0
#
# Activa los logs para paquetes anormales o excepcionales
#
net.ipv4.conf.all.log_martians = 1
net.ipv4.conf.default.log_martians = 1
#
# Ignorar peticiones broadcast
#
net.ipv4.icmp_echo_ignore_broadcasts = 1
#
# Ignorar mensajes de error mal formados
#
net.ipv4.icmp_ignore_bogus_error_responses = 1
#
# Protegerse ante ataques tcp syn
#
net.ipv4.tcp_syncookies = 1
#
# Habilitar reverse path filtering
#
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.default.rp_filter = 1
#
```

PARÁMETROS

#Deshabilitar vulnerabilidad de marca de tiempo en TCP

#

#net.ipv4.tcp_timestamps = 0

#

#Bloqueo de ipv6

#

#net.ipv6.conf.all.disable_ipv6 = 1

#net.ipv6.conf.default.disable_ipv6 = 1

#

#Bloqueo de core dumps de programas con SUID

#

fs.suid_dumpable = 0

#

El tamaño de las colas de espera de TCP

#

#net.ipv4.tcp_max_syn_backlog = 1280

2.5. CONFIGURACION Y PROTECCIÓN DE REGISTROS DE ACTIVIDAD

La configuración de registros de actividad en sistemas Linux desempeña un papel fundamental en la supervisión, mantenimiento de la seguridad y auditoría del sistema. Este apartado se sumerge en la importancia de establecer una adecuada recopilación y gestión de registros. Exploraremos cómo configurar de manera efectiva los registros de actividad para detectar y responder a eventos de seguridad, garantizando la integridad y disponibilidad de la información en sistemas Linux.

Además, se establecerá el tamaño máximo del archivo de registro de auditoría (10MB), la cantidad de archivos de registro que se debe mantener (12) y la acción cuando el archivo de registro de auditoría alcance su tamaño máximo (en este caso ROTATE, creando un nuevo archivo de registro y conservando los antiguos). Se establecen las siguientes configuraciones sobre la herramienta Audit. A continuación, se detallan todos los parámetros configurados.

La configuración de este paso está dentro del fichero `/etc/audit/auditd.conf`.

2.5.1. INTENTOS EXITOSOS Y NO EXITOSOS DE LEER INFORMACIÓN DE LOS REGISTROS DE AUDITORÍA

PARÁMETROS

`-w /var/log/audit/ -k auditlog`

2.5.2. MODIFICACIONES A LA CONFIGURACIÓN DE AUDITORÍA

PARÁMETROS
-w /etc/audit/ -p wa -k auditconfig -w /etc/libaudit.conf -p wa -k auditconfig

2.5.3. SUPERVISAR EL USO DE HERRAMIENTAS DE GESTIÓN DE AUDITORÍA

PARÁMETROS
-w /sbin/auditctl -p x -k audittools -w /sbin/auditd -p x -k audittools

2.5.4. REGLAS DE EJECUCIÓN

PARÁMETROS
-w /etc/passwd -p wa -k passwd_changes -w /etc/selinux/ -p wa -k selinux_changes -w /usr/local/sbin -p x -k eject_commands -w /usr/local/bin -p x -k eject_commands -w /bin -p x -k eject_commands -w /sbin -p x -k eject_commands -w /usr/sbin -p x -k eject_commands -w /usr/bin -p x -k eject_commands

2.5.5. REGLAS DE MÓDULOS

PARÁMETROS
-w /usr/sbin/insmod -p x -k modules -w /usr/sbin/rmmod -p x -k modules -w /usr/sbin/modprobe -p x -k modules -a always,exit -F arch=b64 -S init_module -S delete_module -k modules

2.5.6. REGLAS DE TIEMPO

PARÁMETROS
-a always,exit -F arch=b64 -S adjtimex -k audit_time_rules -a always,exit -F arch=b64 -S settimeofday -k audit_time_rules -a always,exit -F arch=b64 -S adjtimex -S settimeofday -S clock_settime -k audit_time_rules -a always,exit -F arch=b64 -S clock_settime -k audit_time_rules -w /etc/localtime -p wa -k audit_time_rules

PARÁMETROS

2.5.7. MODIFICACIÓN DE GRUPOS DE USUARIO

PARÁMETROS

-w /etc/group -p wa -k audit_rules_usergroup_modification
-w /etc/passwd -p wa -k audit_rules_usergroup_modification
-w /etc/gshadow -p wa -k audit_rules_usergroup_modification
-w /etc/shadow -p wa -k audit_rules_usergroup_modification
-w /etc/security/opasswd -p wa -k audit_rules_usergroup_modification

2.5.8. MODIFICACIÓN DE RED

PARÁMETROS

-a always,exit -F arch=b64 -S sethostname -S setdomainname -k audit_rules_networkconfig_modification
-w /etc/issue -p wa -k audit_rules_networkconfig_modification
-w /etc/issue.net -p wa -k audit_rules_networkconfig_modification
-w /etc/hosts -p wa -k audit_rules_networkconfig_modification
-w /etc/sysconfig/network -p wa -k audit_rules_networkconfig_modification

2.5.9. CONTROL DE ACCESO

PARÁMETROS

-a always,exit -F arch=b64 -F auid=0 -S unlink -S unlinkat -S rename -S renameat -k root_delete
-a always,exit -F arch=b64 -S unlink -S unlinkat -S rename -S renameat -k user_delete
-a always,exit -F arch=b64 -S chmod -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S chown -S fchown -S fchownat -S lchown -k change_perms
-a always,exit -F arch=b64 -S chown -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S fchmod -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S fchmodat -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S fchown -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S fchownat -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S fremovexattr -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S fsetxattr -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S lchown -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S lremovexattr -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S lsetxattr -F auid>=1000 -F auid!=4294967295 -k perm_mod
-a always,exit -F arch=b64 -S removexattr -F auid>=1000 -F auid!=4294967295 -k perm_mod

PARÁMETROS

```
-a always,exit -F arch=b64 -S setxattr -F auid>=1000 -F auid!=4294967295 -k perm_mod  
-a always,exit -F arch=b64 -S creat -S open -S openat -S open_by_handle_at -S truncate -S ftruncate -F  
exit=-EACCES -F auid>=1000 -F auid!=4294967295 -k access  
-a always,exit -F arch=b64 -S creat -S open -S openat -S open_by_handle_at -S truncate -S ftruncate -F  
exit=-EPERM -F auid>=1000 -F auid!=4294967295 -k access  
-a always,exit -F arch=b64 -S mount -F auid>=1000 -F auid!=4294967295 -k export  
-a always,exit -F arch=b64 -S rmdir -S unlink -S unlinkat -S rename -S renameat -F auid>=1000 -F  
auid!=4294967295 -k delete  
-w /etc/sudoers -p wa -k actions
```

2.5.10. ACTIVIDADES SOSPECHOSAS

PARÁMETROS

```
-w /usr/bin/wget -p x -k susp_activity  
-w /usr/bin/curl -p x -k susp_activity  
-w /usr/bin/base64 -p x -k susp_activity  
-w /bin/nc -p x -k susp_activity  
-w /bin/netcat -p x -k susp_activity  
-w /usr/bin/ncat -p x -k susp_activity  
-w /usr/bin/ssh -p x -k susp_activity  
-w /usr/bin/socat -p x -k susp_activity  
-w /usr/bin/wireshark -p x -k susp_activity  
-w /usr/bin/rawshark -p x -k susp_activity  
-w /usr/bin/rdesktop -p x -k sbin_susp  
-w /sbin/iptables -p x -k sbin_susp  
-w /sbin/ifconfig -p x -k sbin_susp  
-w /usr/sbin/tcpdump -p x -k sbin_susp  
-w /usr/sbin/traceroute -p x -k sbin_susp
```

2.6. USUARIOS INNECESARIOS Y SHELLS PREDETERMINADAS

La administración de **usuarios innecesarios y shells predeterminadas** en sistemas Linux es un aspecto esencial de la seguridad y la eficiencia operativa. Este apartado se centra en la identificación y eliminación de usuarios innecesarios en el sistema. La gestión adecuada de usuarios innecesarios es un paso fundamental para garantizar un entorno de cómputo más seguro y eficiente.

Además, se cambia la shell de /nologin por /false a salvo root y usuarios del sistema que está en el grupo sudoers corrigiendo las shell en caso de no ser correcto.

La configuración de este paso está dentro del fichero /etc/passwd.

CAPTURA

```
-----
-- COMPROBACIÓN usuarios del sistema --
-----
root:x:0:0:root:/root:/bin/bash
messagebus:x:499:498:User for D-Bus:/run/dbus:/bin/false
tftp:x:498:497:TFTP Account:/srv/tftpboot:/bin/false
srvGeoClue:x:497:496:User for GeoClue D-Bus service:/var/lib/srvGeoClue:/bin/false
nobody:x:65534:65534:nobody:/var/lib/nobody:/bin/false
man:x:13:62:Manual pages viewer:/var/lib/empty:/bin/false
mail:x:496:495:Mailer daemon:/var/spool/clientmqueue:/bin/false
lp:x:495:494:Printing daemon:/var/spool/lpd:/bin/false
daemon:x:2:2:Daemon:/sbin:/bin/false
bin:x:1:1:bin:/bin:/bin/false
pulse:x:494:479:PulseAudio daemon:/var/lib/pulseaudio:/bin/false
firebird:x:493:478:Firebird SQL server:/srv/firebird:/bin/false
dnsmasq:x:492:477:dnsmasq:/var/lib/empty:/bin/false
avahi:x:491:476:User for Avahi:/run/avahi-daemon:/bin/false
brltty:x:490:475:Braille Device Daemon:/var/lib/brltty:/bin/false
chrony:x:489:473:Chrony Daemon:/var/lib/chrony:/bin/false
flatpak:x:471:471:Flatpak system helper:/bin/false
postfix:x:51:51:Postfix Daemon:/var/spool/postfix:/bin/false
polkitd:x:470:470:User for polkitd:/var/lib/polkit:/bin/false
scard:x:469:469:Smart Card Reader:/run/pcscd:/bin/false
rtkit:x:468:468:RealtimeKit:/var/lib/empty:/bin/false
systemd-timesync:x:467:467:systemd Time Synchronization:/bin/false
nscd:x:466:466:User for nscd:/run/nscd:/bin/false
rpc:x:465:65534:user for rpcbind:/var/lib/empty:/bin/false
usbmux:x:464:65533:usbmuxd daemon:/var/lib/usbmuxd:/bin/false
statd:x:463:65533:NFS statd daemon:/var/lib/nfs:/bin/false
sshd:x:462:462:SSH daemon:/var/lib/ssh:/bin/false
colord:x:461:461:user for colord:/var/lib/colord:/bin/false
nm-openconnect:x:460:460:NetworkManager user for OpenConnect:/var/lib/nm-openconnect:/bin/false
nm-openvpn:x:459:459:NetworkManager user for OpenVPN:/var/lib/openvpn:/bin/false
vnc:x:458:458:user for VNC:/var/lib/empty:/bin/false
gdm:x:457:457:Gnome Display Manager daemon:/var/lib/gdm:/bin/false
admin:x:1000:100:admin:/home/admin:/bin/bash
fwupd-refresh:x:456:456:Firmware update daemon:/var/lib/fwupd:/bin/false
-----
-- USUARIOS CON UID >= 1000 --
-----
nobody:65534:/bin/false
admin:1000:/bin/bash
-
```

2.7. CONFIGURACIÓN SEGURA DE GNOME Y BANNER DE LA ORGANIZACIÓN

La configuración del escritorio GNOME se gestiona con dconf. Es una base de datos estructurada jerárquicamente o registro que permite a los usuarios modificar sus configuraciones personales, y a los administradores del sistema establecer valores por defecto u obligatorios para todos los usuarios.

Los parámetros de configuración global de dconf pueden establecerse en el directorio /etc/dconf/db/. Esto incluye la configuración para GDM o el bloqueo de ciertas opciones de configuración para los usuarios.

Se crearán ficheros con el contenido personalizando las medidas de seguridad que la compañía crea conveniente.

En el archivo sito en /etc/dconf/profile/user se establece como se priorizan las bases de datos de configuraciones dconf.

PARÁMETROS
user-db:user system-db:local

En el archivo sito en /etc/dconf/profile/gdm gestiona las configuraciones del gestor de pantalla GDM:

PARÁMETROS
user-db:user system-db:gdm file-db:/usr/share/gdm/greeter-dconf-defaults

En el archivo sito en /etc/dconf/db/gdm.d/01-banner-message establece el banner que se mostrará en la pantalla de inicio de sesión con entorno gráfico.

En el archivo sito en /etc/dconf/db/gdm.d/00-login-screen se establece la siguiente configuración:

PARÁMETROS
[org/gnome/login-screen] # Do not show the user list disable-user-list=true

En el archivo sito en /etc/dconf/db/local.d/00-screensaver se establece la siguiente configuración:

PARÁMETROS
Specify the dconf path [org/gnome/desktop/session] # Number of seconds of inactivity before the screen goes blank idle-delay=uint32 600 # Specify the dconf path [org/gnome/desktop/screensaver] # Lock the screen after the screen is blank lock-enabled=true # Number of seconds after the screen is blank before locking the screen lock-delay=uint32 1

En el archivo sito en `/etc/dconf/db/local.d/locks/screensaver` se establece la siguiente configuración:

PARÁMETROS
Lock desktop screensaver settings <code>/org/gnome/desktop/session/idle-delay</code> <code>/org/gnome/desktop/screensaver/lock-enabled</code> <code>/org/gnome/desktop/screensaver/lock-delay</code>

En el archivo sito en `/etc/dconf/db/local.d/03-privacy` se establece la siguiente configuración:

PARÁMETROS
<code>[org/gnome/desktop/media-privacy]</code> <code>hide-identity=true</code> <code>old-files-age=0</code> <code>remember-recent-files=false</code> <code>remove-old-temp-files=true</code>

En el archivo sito en `/etc/dconf/db/local.d/07-media-handling` se establece la siguiente configuración:

PARÁMETROS
<code>[org/gnome/desktop/media-handling]</code> <code>automount=false</code> <code>automount-open=false</code> <code>autorun-never=true</code>

En el archivo sito en `/etc/dconf/db/local.d/08-wm` establece el número de escritorios virtuales:

PARÁMETROS
<code>[org/gnome/desktop/wm/preferences]</code> <code>num-workspaces=1</code>

La **configuración segura de Gnome** se introduce a mano, es un mensaje disuasorio al inicio (información que contiene el banner será otorgada por la Organización) y solicite usuario y contraseña, así mismo, se configura un tiempo mínimo de bloqueo de 10 minutos (600 segundos).

La configuración de este paso está dentro del fichero `/etc/issue`, `/etc/issue.net` y `/etc/motd`. Las comprobaciones mostradas a continuación son de acceso por terminal SSH.

CAPTURA

Como también acceso por la propia interfaz de *SUSE Linux Enterprise 15*.



2.8. LÍMITES PERMISOS Y CADUCIDAD DE CONTRASEÑAS

La configuración de **límites de recursos, permisos y caducidad de contraseñas** de los usuarios sin privilegios es un elemento esencial de la seguridad en sistemas Linux. Es de gran importancia restringir cuidadosamente los privilegios de los usuarios no administrativos. La limitación de los permisos para los usuarios sin privilegios es una medida crítica para proteger los sistemas y la información que contienen, en particular limitar los volcados de núcleo.

La configuración de la caducidad de contraseñas es un aspecto esencial de la gestión de la seguridad en los sistemas Linux. Es importante establecer las políticas de caducidad de contraseñas adecuadas. La configuración de la caducidad de las contraseñas es una medida crítica para proteger las cuentas de usuario y reducir el riesgo de acceso no autorizado en los sistemas Linux. Señalar que, al finalizar este paso del bastionado, se deberá cambiar la contraseña de los usuarios del sistema existentes.

Para la caducidad de las credenciales se han establecido las siguientes configuraciones (en la ruta del fichero `/etc/login.defs`).

- Vigencia de las contraseñas: 90 días.
- Mínimo de días antes del siguiente cambio de contraseña: 2 días.
- Aviso antes de la caducidad de las contraseñas: 10 días.

CAPTURA

```
admin@localhost:~> sudo grep -v "#" /etc/login.defs | grep "PASS_"
PASS_MAX_DAYS    90
PASS_MIN_DAYS    10
PASS_WARN_AGE    2
```

La configuración de la complejidad de contraseñas es un componente esencial de la seguridad en los sistemas Linux. Se debe establecer políticas de complejidad de contraseñas efectivas. La configuración de la complejidad de las contraseñas es una medida fundamental para proteger las cuentas de usuario y reducir el riesgo de intrusiones en los sistemas Linux.

- Mínimo doce (12) caracteres.
- Al menos un (1) carácter como mínimo en minúscula.
- Al menos un (1) carácter como mínimo en mayúscula.
- Al menos un (1) dígito como mínimo.

2.9. BLOQUEO POR INTENTOS FALLIDOS

La configuración de los archivos “common-auth” y “common-password”, desempeñan un papel crítico en el control del acceso y la autenticación de los usuarios en sistemas Linux del **bloqueo de cuentas por intentos fallidos**. Este apartado se adentra en la importancia de configurar estos archivos de manera efectiva para fortalecer la seguridad del sistema. En este caso se establecen las siguientes medidas de seguridad de acuerdo con las guías de seguridad utilizadas. Hay que apuntar que en caso de bloqueo de root por intentos fallidos, a los 30 minutos se desbloqueará automáticamente. Será necesario valorar la configuración previa de los archivos de pam.d antes de bastionar en función de las necesidades y el estado del sistema del cliente, así mismo, se deberá tener externo cuidado en la manipulación de los archivos que se reseñan a continuación.

En caso de que hubiera problemas en el cambio de contraseña o autenticación (como inicio de sesión exitosos como errores) la cuenta quedara bloqueada, será necesario añadir al archivo de configuración de pam.d “common-account” en la ruta /etc/pam.d/common-account la siguiente configuración:

PARÁMETROS

#%PAM-1.0

account	required	pam_tally2.so
----------------	-----------------	----------------------

En el archivo sito en /etc/pam.d/common-auth, se establece la siguiente configuración:

PARÁMETROS

#%PAM-1.0

auth	required	pam_env.so
auth	required	pam_tally2.so deny=8 onerr=fail unlock_time=1800
auth	sufficient	pam_unix.so try_first_pass

PARÁMETROS		
auth	required	pam_deny.so
auth	requisite	pam_nologin.so
auth	include	common-auth
account	include	common-account
password	include	common-password
session	required	pam_loginuid.so
session	optional	pam_keyinit.so force revoke
session	include	common-session
#session	optional	pam_lastlog.so nowtmp showfailed
session	optional	pam_mail.so standard

En el archivo sito en /etc/pam.d/common-password, se establece la siguiente configuración:

PARÁMETROS		
#%PAM-1.0		
auth	required	pam_env.so
auth	required	pam_tally2.so deny=8 onerr=fail unlock_time=1800
auth	sufficient	pam_unix.so try_first_pass
auth	required	pam_deny.so
auth	sufficient	pam_rootok.so
auth	include	common-auth
account	sufficient	pam_rootok.so
account	include	common-account
password	include	common-password
session	include	common-session
session	optional	pam_xauth.so

2.10. CONFIGURACIÓN DEL SISTEMA DE FICHEROS Y PERMISOS

La configuración adecuada del sistema de ficheros en sistemas Linux es esencial para optimizar el rendimiento y la estabilidad del sistema. Este apartado se adentra en la importancia de ajustar los parámetros de particiones según las necesidades específicas del entorno. A continuación, se detallan todos los parámetros configurados.

Se modifica los permisos en el fichero de configuración de boot (en la ruta del fichero /etc/fstab).

PARÁMETROS	
ro	0 0

PARÁMETROS

--COMPROBACION del archivo fstab--

UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/	btrfs	defaults	0	0
UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/var	btrfs	subvol=/@/var	0	0
UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/usr/local	btrfs	subvol=/@/usr/local	0	0
UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/tmp	btrfs	subvol=/@/tmp	0	0
UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/srv	btrfs	subvol=/@/srv	0	0
UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/root	btrfs	subvol=/@/root	0	0
UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/opt	btrfs	subvol=/@/opt	0	0
UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/home	btrfs	subvol=/@/home	0	0
UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/boot/grub2/x86_64-efi	btrfs	subvol=/@/boot/grub2/x86_64-efi,ro	0	0
UUID=f9ce0d04-bb0c-4ea8-aad5-261cf6cfe2db	/boot/grub2/i386-pc	btrfs	subvol=/@/boot/grub2/i386-pc,ro	0	0

2.11. PARÁMETROS SSH

El protocolo SSH (Secure Shell) es una herramienta esencial para la administración remota de servidores en entornos Linux. Sin embargo, para garantizar la seguridad de las conexiones y proteger los sistemas contra posibles amenazas, es crucial llevar a cabo medidas de securización efectivas. La implementación adecuada de estas medidas no solo protege los sistemas, sino que también garantiza la integridad de los datos y la confidencialidad de las comunicaciones del entorno. Apuntar que los puertos, servicios y protocolos de esta guía son orientativos y siempre se deberá ajustar a las necesidades de la Organización. A continuación, se detallan todos los parámetros configurados.

La configuración de este paso está dentro del fichero /etc/ssh/sshd_config:

PARÁMETROS

```
Port 22
Protocol 2
LogLevel VERBOSE
PermitRootLogin no
PrintLastLog yes
AllowTcpForwarding no
X11Forwarding no
HostbasedAuthentication no
PasswordAuthentication yes
PermitEmptyPasswords no
Banner /etc/issue
TCPKeepAlive yes
UsePAM yes
LoginGraceTime 300
MaxAuthTries 8
MaxSessions 2
```


3. MODIFICACIONES EN EL BASTIONADO

3.1. CONFIGURAR APPARMOR

AppArmor (Application Armor) es un módulo de seguridad para el núcleo Linux que proporciona un enfoque basado en políticas para restringir las capacidades de los programas en un sistema. En *SUSE Linux Enterprise 15*, AppArmor es una de las herramientas integradas para la seguridad del sistema mediante el control de acceso obligatorio (MAC, Mandatory Access Control).

Debido a la infraestructura y los aplicativos propios del cliente, no es necesario que este activado AppArmor.

PASO	CONFIGURACIÓN
1.	Abra la terminal para realizar las siguientes comprobaciones
2.	Comprobar que el servicio “apparmor” está parado y deshabilitado <pre>admin@localhost:~> sudo systemctl stop apparmor admin@localhost:~> sudo systemctl status apparmor ○ apparmor.service - Load AppArmor profiles Loaded: loaded (/usr/lib/systemd/system/apparmor.service; enabled; preset: enabled) Active: inactive (dead) since Thu 2025-09-11 20:35:02 CEST; 30s ago Duration: 1h 14min 56.786s Process: 701 ExecStart=/lib/apparmor/apparmor.systemd reload (code=exited, status=0/SUCCESS) Process: 5803 ExecStop=/bin/true (code=exited, status=0/SUCCESS) Main PID: 701 (code=exited, status=0/SUCCESS) CPU: 2ms sep 11 19:20:05 localhost systemd[1]: Starting Load AppArmor profiles... sep 11 19:20:05 localhost apparmor.systemd[701]: Restarting AppArmor sep 11 19:20:05 localhost apparmor.systemd[701]: Reloading AppArmor profiles sep 11 19:20:05 localhost systemd[1]: Finished Load AppArmor profiles. sep 11 20:35:02 localhost.localdomain systemd[1]: Stopping Load AppArmor profiles... sep 11 20:35:02 localhost.localdomain systemd[1]: apparmor.service: Deactivated successfully. sep 11 20:35:03 localhost.localdomain systemd[1]: Stopped Load AppArmor profiles. admin@localhost:~> sudo systemctl disable --now apparmor Removed "/etc/systemd/system/multi-user.target.wants/apparmor.service".</pre>

3.2. CADUCIDAD DE LA CONTRASEÑA DE ROOT

Se modifica la caducidad de la contraseña del usuario “root” aumentando su duración máxima a 90 días.

PARÁMETROS

```
admin@localhost:~> sudo /usr/bin/chage -m 2 -M 90 -W 10 root
[sudo] contraseña para root:
admin@localhost:~> sudo chage --list root
Último cambio de contraseña                : sep 11, 2025
La contraseña caduca                        : dic 10, 2025
Contraseña inactiva                        : nunca
La cuenta caduca                           : nunca
Número de días mínimo entre cambio de contraseña : 2
Número de días máximo entre cambio de contraseña : 90
Número de días de aviso antes de que caduque la contraseña : 10
```